

A1 — Đăng ký & Đăng nhập

Mô tả

Cổng vào của hệ thống. Cho phép người dùng tạo tài khoản, đăng nhập và khôi phục mật khẩu qua OTP email. Sau khi đăng nhập, hệ thống tự phân biệt role và chuyển đến đúng trang.

Đối tượng sử dụng

Người dùng	Vai trò
Bệnh nhân	Đăng ký, đăng nhập
Bác sĩ	Đăng nhập (tài khoản bắt đầu là role='user', đổi thành 'doctor' khi Admin duyệt hồ sơ ở C2)
Admin	Đăng nhập (tài khoản tạo sẵn trong DB, không đăng ký qua form)

Luồng nghiệp vụ

1. Đăng ký tài khoản

- Người dùng điền: email, mật khẩu (≥ 8 ký tự), họ tên, số điện thoại (tùy chọn).
- Server kiểm tra email chưa tồn tại (UNIQUE).
- Hash mật khẩu bằng bcrypt (10 rounds), lưu vào `users` với `role = 'user'`, `status = 'active'`.
- Chuyển sang trang đăng nhập. Hệ thống gợi ý tạo nhóm gia đình (A2) ngay sau lần đăng nhập đầu tiên.

2. Đăng nhập

- Người dùng nhập email và mật khẩu.
- Server kiểm tra: email tồn tại $\rightarrow$ `status = 'active'` $\rightarrow$ so sánh bcrypt.
- Tạo JWT (hết hạn 7 ngày), trả về cho client, lưu vào `localStorage`.
- Redirect theo `users.role`: `user` $\rightarrow$ `/dashboard`, `doctor` $\rightarrow$ `/doctor`, `admin` $\rightarrow$ `/admin`.
- Lưu ý role:** Người dùng đăng ký hồ sơ bác sĩ (B1) vẫn có `role = 'user'` cho đến khi Admin duyệt (C2). Sau khi được duyệt, `role` đổi thành `'doctor'` và lần đăng nhập tiếp theo sẽ redirect vào trang bác sĩ.

3. Quên mật khẩu

- Người dùng nhập email $\rightarrow$ server kiểm tra email tồn tại.
- Invalidated OTP cũ:** Trước khi tạo OTP mới, đánh dấu tất cả OTP cũ của user này thành `used = true`.

- 3. Tạo OTP mới 6 chữ số, hết hạn 15 phút, lưu vào `password_resets`.
- 4. Gửi OTP qua Gmail SMTP.
- 5. Người dùng nhập OTP → server xác minh: còn hạn và `used = false`.
- 6. Nhập mật khẩu mới → hash và cập nhật, đánh dấu OTP `used = true`.

4. Cập nhật thông tin cá nhân

- 1. Người dùng sửa họ tên, số điện thoại, ảnh đại diện.
- 2. Email không được thay đổi sau khi đăng ký (liên kết danh tính trong hệ thống).
- 3. Lưu ý: Thông tin trong `users` (tên, ảnh) và thông tin trong `members` (A2) là độc lập nhau — sửa profile không tự cập nhật vào hồ sơ thành viên gia đình.

Bảng dữ liệu liên quan

Bảng	Mục đích
<code>users</code>	Tài khoản: email (unique), mật khẩu hash, role, trạng thái
<code>password_resets</code>	OTP quên mật khẩu (có thời hạn, chỉ dùng 1 lần)

API Endpoints

Method	Endpoint	Auth	Mô tả
POST	<code>/api/auth/register</code>	✗	Đăng ký tài khoản mới
POST	<code>/api/auth/login</code>	✗	Đăng nhập, nhận JWT
GET	<code>/api/auth/me</code>	✓	Lấy thông tin user hiện tại
PUT	<code>/api/users/profile</code>	✓	Cập nhật tên, SĐT, ảnh (không cập nhật email)
POST	<code>/api/auth/forgot-password</code>	✗	Gửi OTP (tự invalidate OTP cũ)
POST	<code>/api/auth/verify-otp</code>	✗	Xác nhận mã OTP
POST	<code>/api/auth/reset-password</code>	✗	Đặt mật khẩu mới
POST	<code>/api/auth/logout</code>	✓	Đăng xuất (xoá token phía client)

Ràng buộc & Quy tắc nghiệp vụ

- Email phải là duy nhất, không được thay đổi sau khi đăng ký.
- Mật khẩu tối thiểu 8 ký tự — kiểm tra cả client lẫn server.

- Khi yêu cầu OTP mới → OTP cũ bị **invalidate ngay lập tức**.
- OTP hết hạn sau **15 phút** và chỉ dùng được **1 lần**.
- Tài khoản (`status = 'locked'`) không đăng nhập được — trả 403 kèm thông báo.
- `users.role` chỉ đổi thành `'doctor'` khi Admin **duyệt hồ sơ** (C2), không phải khi submit hồ sơ (B1).
- Admin không thể bị khoá qua giao diện (C1 bảo vệ). Nếu Admin tự khoá mình qua DB thì chỉ sửa được qua DB trực tiếp.
- Đăng xuất chỉ xoá token phía client. Token vẫn hợp lệ trên server đến khi hết hạn — đây là **thiết kế có chủ đích** để đơn giản hóa (stateless JWT).

Giao diện cần xây dựng

- `/register` — form đăng ký
- `/login` — form đăng nhập
- `/forgot-password` — nhập email
- `/verify-otp` — nhập mã OTP
- `/reset-password` — nhập mật khẩu mới
- `/profile` — xem và sửa thông tin cá nhân

Chức năng liên quan

- **A2** — Sau đăng nhập lần đầu, bệnh nhân được gợi ý tạo nhóm gia đình
- **B1** — Bác sĩ cần tài khoản A1 trước khi đăng ký hồ sơ
- **C1** — Admin khoá/mở khoá tài khoản trong bảng `users`
- **C2** — Admin duyệt hồ sơ → `users.role` đổi thành `'doctor'`